



Conformidade TI

Auditoria de Conformidade

LGPD, Métodos e Riscos

Professor Thyago Aquino



Problema e Objetivo

A auditoria de conformidade é crucial para **provar a conformidade** com a LGPD, especialmente após incidentes que comprometem dados pessoais. Vamos explorar seus objetivos e métodos.



O que é Auditoria?

EXIGÊNCIA LEGAL

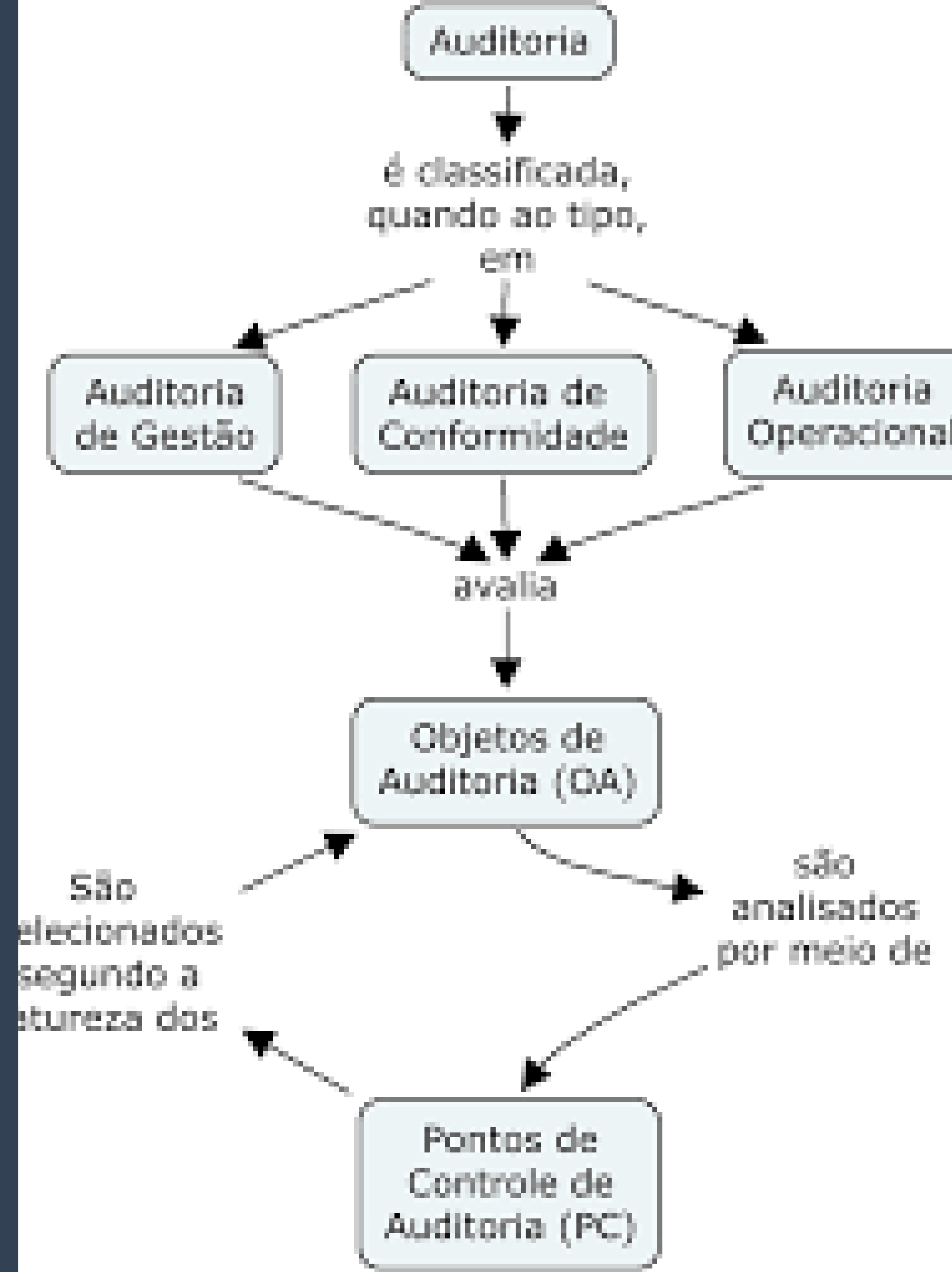
A LGPD estabelece diretrizes claras que as organizações devem seguir para proteger os dados pessoais, garantindo que a conformidade seja não apenas uma obrigação, mas uma responsabilidade contínua.

DECLARAÇÃO ORGANIZACIONAL

As políticas e processos da organização devem estar alinhados com as exigências legais, refletindo um compromisso com a transparência e a proteção dos dados, promovendo a confiança do usuário.

Objetos de Auditoria

Nesta seção, abordaremos os principais **componentes examinados** durante a auditoria de conformidade, incluindo dados, fluxos de informações, controles e acessos relevantes em sistemas de informação.



Controles e Confiabilidade

DECLARATIVOS

Os controles **declarativos** incluem políticas e termos, oferecendo baixa garantia isolada. Eles servem como diretrizes, mas sua eficácia depende da aplicação prática e do comprometimento da organização.

TÉCNICOS

Os controles **técnicos**, como criptografia e gerenciamento de acesso, oferecem alta auditabilidade. Eles são fundamentais para a proteção dos dados, garantindo integridade e confidencialidade nas operações organizacionais.

Controles de Conformidade de Software

Tipo de controle	Exemplo	Natureza
Processual	fluxo de atendimento ao titular	Organizacional
Técnico	criptografia, firewall	Tecnologia
Administrativo	políticas e normas	Governança

Auditoria Baseada em Evidências

A Auditoria Baseada em Evidências é um método moderno essencial para garantir a conformidade, utilizando uma hierarquia de evidências que fornece suporte robusto para as conclusões.

EVIDENCE A PPUS.



Walkthrough do Fluxo do Dado

EXPOSIÇÃO DE DADOS

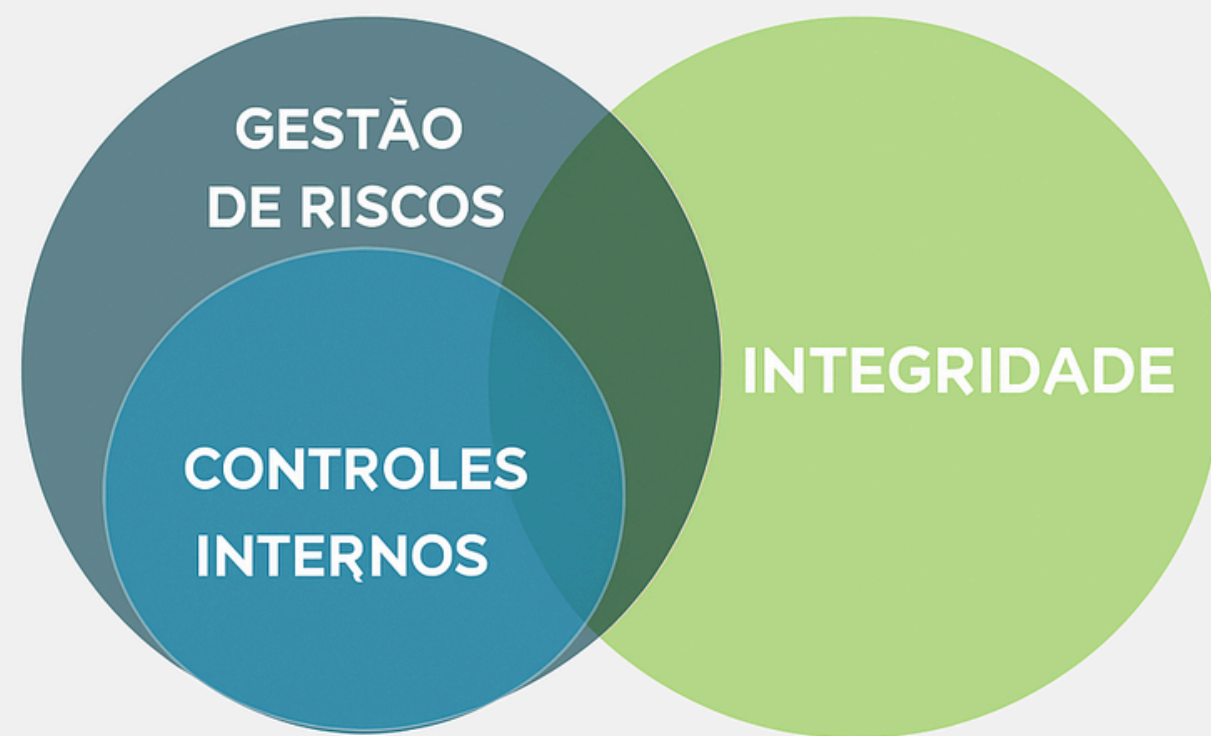
Identificar a **exposição de dados** é crucial. Avaliar onde informações sensíveis podem ser acessadas indevidamente ajuda a fortalecer a segurança e mitigar riscos potenciais para a organização.

CRIPTOGRAFIA E SEGURANÇA

A implementação de **criptografia em trânsito e em repouso** é vital. Isso protege os dados contra acessos não autorizados, garantindo que a informação permaneça confidencial e íntegra durante todo o ciclo de vida.

Teste de Controles

Esta é a interação entre os instrumentos de governança



DESIGN

O design de controles é fundamental para garantir que as medidas de segurança atendam às exigências legais e organizacionais, proporcionando uma base sólida para a proteção de dados.

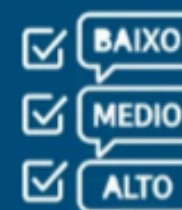
OPERAÇÃO

A operação dos controles deve ser avaliada para assegurar que funcionam conforme o planejado, minimizando riscos e garantindo a conformidade com a LGPD e as políticas internas.

Amostragem Orientada a Risco

A amostragem orientada a risco consiste em selecionar **dados, processos e sistemas com maior probabilidade de falhas ou maior impacto no negócio**, priorizando a análise de informações sensíveis e serviços críticos. Essa abordagem aumenta a eficiência da auditoria ao direcionar esforços para onde o risco é mais relevante.

Tipos de Matriz de Risco



MATRIZ DE RISCO QUALITATIVA

Classifica probabilidade e impacto por descrições (Baixo, Médio, Alto); simples e rápida.



MATRIZ DE RISCO QUANTITATIVA

Usa dados numéricos para avaliar riscos com precisão; ideal para estimar custos.



MATRIZ DE RISCO SEMI-QUANTITATIVA

Combina números e categorias descritivas; útil quando há dados parciais.



MATRIZ DE PROBABILIDADE × IMPACTO (P-I)

Formato clássico com probabilidade no eixo vertical e impacto no horizontal.



MATRIZ INERENTE × RESIDUAL (OU ATUAL) × ALVO

Mostra riscos antes, depois e no nível desejado de mitigação.



MATRIZ PARA ANÁLISE DECENÁRIOS ESTRATÉGICOS

Avalia riscos em contextos futuros ou hipotéticos, apoiando decisões estratégicas.

Identificação de Riscos

A identificação de riscos em auditoria é fundamental para proteger os ativos de informação. Envolve entender as ameaças e vulnerabilidades que podem comprometer a segurança dos dados.

Conceito	Ameaça	Risco
O que é	Evento ou agente que causa dano	Probabilidade + impacto
Natureza	Potencial	Avaliação
Exemplo	Hacker, vírus, falha elétrica	Alta chance de invasão
Depende de	Existência da ameaça	Vulnerabilidade + impacto

Risco = Ameaça + Vulnerabilidade + Impacto



Análise de Impacto

A Análise de Impacto à Proteção de Dados (DPIA) é um processo estruturado que identifica, avalia e documenta os riscos relacionados ao tratamento de dados pessoais, permitindo a adoção de medidas de mitigação e garantindo conformidade com a LGPD, além de proteger os direitos e liberdades dos titulares.

“A DPIA é como um raio-x do risco antes de tratar dados pessoais.”

Data Impact Assessment

